

ATT&CK Based Practice Guide Evaluation

Final Presentation



Team:

Anmol Agarwal, Rhiannon Jones and
Evelyn Wong

Mentor:

Dr. Bhavani Thuraisingham
Brian Ricks

MITRE

Sponsor:

Harry Perper,
Department Chief Engineer (P1A1)
The MITRE Corporation

Overview

- Project Summary
- Tabletop Exercise Results
- Future Work

Project Summary

Description

- Identify security gaps in the NCCoE Access Rights Management Practice Guide
- Use tactics and techniques in the MITRE ATT&CK Enterprise Matrix
- Perform tabletop exercise
 - Design theoretical attacks against the architecture to bypass the security features
 - Map these attacks to MITRE ATT&CK tactics and techniques

Tabletop Exercise Results

Privilege Escalation

SCENARIO: An attacker finds and exploits a vulnerability in one of the tools in your system. From there, the attacker moves laterally through the system until they are able to escalate the privileges of the account they've exploited or create a new high privilege account that can access the system.

Tactic ID	Tactic	Technique ID	Technique Name	Data Source 1	Data Source 2	Data Source 3	Data Source 4
TA0001	Initial Access	T1190	Exploit public facing Application	Application Logs	Packet Capture	Web Logs, Web Application Firewall Logs	
TA0004	Privilege Escalation	T1068	Exploitation for Privilege Escalation	1000, 1001 Windows Error Reporting	4688 Process Execution	Application Logs	
TA0005	Defense Evasion	T1211	Exploitation for Defense Evasion	4688 Process Execution	4663 File Monitoring	1000, 1001 Windows Error Reporting	
TA0006	Credential Access	T1098	Account Manipulation	4624 Authentication Logs	Windows Event Logs	Packet Capture	API monitoring
TA0008	Lateral Movement	T1075	Pass the Hash	4624 Authentication Logs			

Privilege Escalation - Results

- Detection
 - A log event is generated when a new account is created or when the privileges for an account are escalated
 - The system would be able to detect this attack and generate an alert that the privilege escalation attack is occurring
- Prevention
 - Security patches should be installed as soon as they are available to reduce the probability that an attacker could find a vulnerability to exploit
- Response
 - Revert the changes that were made
 - Remove the account to prevent any further damage

Flooding Attack

SCENARIO: An attacker gains access to your account database, but the attacker knows that you're using the Access Rights Management Practice Guide as the basis of your system. Instead of adding a single high-privileged account, the attacker floods your account database with new high-privileged accounts. While your security analysts are trying to revert the changes, the attacker uses the high-privileged accounts to access your system.

Tactic ID	Tactic	Technique ID	Technique Name	Data Source 1	Data Source 2	Data Source 3	Data Source 4
TA0004	Privilege Escalation	T1068	Exploitation for Privilege Escalation	1000, 1001 Windows Error Reporting	4688 Process Execution	Application Logs	
TA005	Defense Evasion	T1222	File and Directory Permissions Modification	4663 File Monitoring	Process Monitoring	4688 Process command-line parameters	Windows event Logs
TA0040	Impact	TA1499	Endpoint Denial of Service	SSL/TLS Inspection	Web Logs	Web Application Firewall Logs	Network Device Logs
TA0040	Impact	T1496	Resource Hijacking	Azure activity Logs	Process use of network	Process Monitoring	Network Protocol Analysis
TA0040	Impact	T1492	Stored Data Manipulation	Application Logs	File Monitoring		
TA0040	Impact	T1485	Data Destruction	4663 File Monitoring	4688 Process Command Line Parameters	Process Monitoring	

Flooding Attack - Results

- Detection
 - A log event is generated when the privileges for an account are escalated
 - The system would be able to detect the privilege escalation attacks and will generate an alert that privilege escalation attacks are occurring
 - Alerts are generated when the attacker accesses system resources
 - The system will detect what the attacker does with their high-privileged account
 - Despite detection, the attack could still be successful
 - System administrators will have to address all alerts that were generated
 - There might be a delay before the administrators can revert all the changes
 - The attacker can access system resources with high-privileged accounts while changes are being reverted

Flooding Attack - Results

- Prevention
 - Security patches should be installed as soon as they are available to reduce the probability that an attacker could find a vulnerability to exploit that would let the attacker execute this attack
- Response
 - Revert the changes that were made as soon as possible
 - New accounts should be removed to prevent further damage

Account Manipulation

SCENARIO: An attacker gains access to your AlertEnterprise installation. The attacker changes the access approval owner to an account they control. With their newfound approval authority, the attacker creates new accounts and escalates the privileges of their newly created accounts.

Tactic ID	Tactic	Technique ID	Technique Name	Data Source 1	Data Source 2	Data Source 3	Data Source 4
TA0002	Execution	T1204	User Execution	4688 Process Command Line	4688 Process Execution	Anti - virus	
TA0003	Persistence	T1098	Account Manipulation	4624 Authentication Logs	Windows Event Logs	Packet Capture	API monitoring
TA0004	Privilege Escalation	T1068	Exploitation for Privilege Escalation	1000, 1001 Windows Error Reporting	4688 Process Execution	Application Logs	
TA0040	Impact	T1222	File and Directory Permissions Modification	4663 File Monitoring	Process Monitoring	4688 Process command-line parameters	Windows event Logs

Account Manipulation - Results

- Detection
 - The system will generate a log event when the AlertEnterprise owner changes
 - The system will generate log events when privileges are escalated
 - The system will detect the attack as soon as the attacker changes the AlertEnterprise owner and will record all of the attacker's changes to account privileges
- Prevention
 - The company should monitor who the owner of the AlertEnterprise approval process is and generate alerts when the AlertEnterprise owner changes
 - Security patches should be installed as soon as they are available
- Response
 - Revert the changes that were made
 - Remove high-privileged account
 - Change the configuration in the AlertEnterprise installation to prevent the attacker from using it

Future Work

Future Work

- This tabletop exercise provides a foundation for other teams to improve on our work
- The tabletop exercise will be done continuously to find more attacks that could be successful in the architecture
 - The architecture is improved with each tabletop exercise iteration

Questions?

References

- [1] B. Strom, A. Applebaum, D. Miller, K. Nickels, A. Pennington and C. Thomas. (2018). “MITRE ATT&CK™: Design and Philosophy,” [online] McLean, VA: MITRE Corporation. Available at: <https://www.mitre.org/sites/default/files/publications/pr-18-0944-11-mitre-attack-design-and-philosophy.pdf> [Accessed 27 Sep. 2019].

- [2] B. E. Strom, J. A. Battaglia, M. S. Kemmerer, W. Kupersanin, D. P. Miller, C. Wampler, S. M. Whitley and R. D. Wolf, “Finding Cyber Threats with ATT&CK-Based Analytics,” 2017. Available at: <https://www.mitre.org/sites/default/files/publications/16-3713-finding-cyber-threats%20with%20att&ck-based-analytics.pdf> [Accessed 27 Sep. 2019].

- [3] F. Maymí, R. Bixler, R. Jones and S. Lathrop, "Towards a definition of cyberspace tactics, techniques and procedures," 2017 IEEE International Conference on Big Data (Big Data), Boston, MA, 2017, pp. 4674-4679. doi: 10.1109/BigData.2017.8258514. Available at: <https://ieeexplore.ieee.org/abstract/document/8258514> [Accessed 27 Sep. 2019].

References

- [4] J. Banoczi, S. Edwards, N. Irrechukwu, J. Klosterman, H. Perper, S. Prince, S. Symington, and D. Wynne, “Access Rights Management for the Financial Services Sector,” National Institute of Standards and Technology Special Publication, Gaithersburg, MD, 2017.
- [5] The MITRE Corporation. (2019). CALDERA. [online] Available at: <https://www.mitre.org/research/technology-transfer/open-source-software/caldera> [Accessed 27 Sep. 2019].
- [6] The MITRE Corporation. (2019). MITRE ATT&CK Matrix Poster. [online] Available at: https://attack.mitre.org/docs/ATTACK_Framework_Board_4x3.pdf [Accessed 29 Oct. 2019].